Course Name: Threat Intelligence

Lab Title: Threat Intelligence, Threat Actor Profiling & Attribution

SECTION 1: TECHNICAL INTELLIGENCE ANALYSIS (25 points)

Task 1.1: IOC Categorization and Analysis

Instructions: Review the `shadowbroker_iocs.txt` file and categorize all indicators by type. Document your findings below.

IP Addresses (C2 Servers)

IP Address	ASN	Hosting Provider	Country	Status	First Seen
203.0.113.45	AS12345	CloudServe Inc	Netherlands	Active	2023-01-15
198.51.100.78	AS54321	EuroHost Ltd	Romania	Dormant	2023-02-01
192.0.2.156	AS99999	NetServe Solutions	Bulgaria	Active	2023-03-10
185.220.101.45	AS205206	Tor Exit Node	Unknown	Dormant	2023-04-15

Malicious Domains

Domain	Registrar	Registration Date	Nameservers	A Record	Status
secure-update.com	NameCheap	2023-01-15	ns1.cloudserve.net	203.0.113.45	Active
verify-session.net	GoDaddy	2023-01-20	ns1.godaddy.com	203.0.113.45	Active

system-check.org	NameCheap	2023-02-01	ns1.cloudserve.net	198.51.100.78	Dormant
backup-verify.net	NameCheap	2023-02-05	ns1.cloudserve.net	198.51.100.78	Dormant
update-check.com	GoDaddy	2023-03-10	ns1.godaddy.com	192.0.2.156	Active
system-update.org	NameCheap	2023-03-15	ns1.cloudserve.net	192.0.2.156	Active
check-version.net	GoDaddy	2023-03-20	ns1.godaddy.com	192.0.2.156	Active

File Hashes

File Type	MD5	SHA256	File Size	Compilation Time	First Seen
Initial Dropper	5d41402abc4b2a76b9719d911017c592	2c26b46911185131006ba5b0e8e5b5e5	245,760 bytes	2023-01-10 14:32:45	2023-01-15
Main Payload	7b52009b64fd0a2a49e6d8a939753077	e3b0c44298fc1c149afbf4c8996fb924	512,000 bytes	2023-01-08 09:15:30	2023-01-15
Credential Dumper	3c59dc048e8850243be8079a5c74d079	6b86b273f403a0c7f6f8b0e5a5b5e5e	128,512 bytes	2023-01-12 11:22:15	2023-02-01
Lateral Movement Tool	1b1a9b5a5a5a5a5a5a5a5a5a5a5a5a	d4735fea8e8c94b5c5c5c5c5c5c5c5c	256,000 bytes	2023-03-05 16:45:20	2023-03-10

Registry Persistence Indicators

Registry Key	Value Type	Data	Purpose	First Observed
HKLM\Software\Microsoft\Windows\Run\SystemCheck	REG_SZ	C:\Windows\System32\svchost.exe -k SystemCheck	System-level persistence	2023-01-15
HKCU\Software\Microsoft\Windows\CurrentVersion\Run\UpdateService	REG_SZ	C:\Users\[USERNAME]\AppData\Roaming\Microsoft\Update\update.exe	User-level persistence	2023-01-20
HKLM\System\CurrentControlSet\Services\ShadowCheck	REG_SZ	C:\Windows\System32\drivers\shadowcheck.sys	Kernel driver persistence	2023-02-01
HKCU\Software\Microsoft\Windows\CurrentVersion\Explorer\Run\VersionCheck	REG_SZ	PowerShell loader	PowerShell-based persistence	2023-03-10

Task 1.2: Infrastructure Pattern Recognition

Instructions: Analyze the infrastructure data and identify clusters and relationships.

. 1: Which domains are hosted on the same IP addresses?

- **185.220.101.45** → `shadowbroker.net` (A record) **and** `command.shadowbroker.net`
- **185.220.102.8** → `shadowbroker.net` (A record) **and** `control.shadowbroker.net`
- **185.220.103.25** → `shadowbroker.net` (A record) **and** `beacon.shadowbroker.net`

. 2: Identify infrastructure clusters (groups of related domains/IPs):

Cluster 1: Netherlands / AS206289 (Bulletproof Hosting) — Primary ops

- **IPs:** 185.220.101.45, 185.220.102.8, 185.220.103.25, 185.220.102.50, 185.220.101.100, 185.220.101.120
- **Domains/Subdomains:**
  - `shadowbroker.net` (apex, A points to the three C2 IPs)
  - `command.shadowbroker.net`, `control.shadowbroker.net`, `beacon.shadowbroker.net`
  - `files.shadowbroker.net` (malware distribution)
  - `shadowbroker-update.com` (phishing)
- **Role:** Primary C2, malware hosting, proxies, and phishing—this is the actor's main production footprint.

Cluster 2: Romania / AS206290 (Hosting Freedom) — Backup & distribution

- **IPs:** 188.40.75.50, 188.40.76.100, 188.40.75.75, 188.40.75.90, 188.40.76.40
- **Domains/Subdomains:**
  - `shadowbroker.io` (apex; two A records)
  - `payload.shadowbroker.net` (hosted here even though it's under `.net`)
  - `shadowbroker-secure.net` (phishing)
- **Role:** Backup C2 namespace (`.io`), proxying, and payload delivery—designed for resilience/failover and campaign agility.

Cluster 3: Russia / AS206291 (FastHost Services) — Tertiary/backup

- **IPs:** 194.67.45.30, 194.67.45.50

- **Domains/Subdomains:**
  - `shadowbroker-backup.com` (apex)
- **Role:** Tertiary C2 and backup infrastructure—kept warm for contingency and diversification.

. 3: What does the infrastructure clustering suggest about threat actor organization?

- **Tiered redundancy** — A primary Netherlands cluster (production C2 + files), a Romanian cluster for **failover and distribution**, and a Russian cluster as a **tertiary fallback**. That three-tier design reduces takedown risk and keeps campaigns online.
- **Centralized certificate and DNS strategy** — Wildcard certs (`*.shadowbroker.net`) and attacker-controlled nameservers show **central management** and likely **automation** for provisioning.
- **Segregation by function** — C2, proxies, phishing, and payload hosting are spread across providers and countries—classic **segmentation** to slow investigators and limit blast radius.
- **Bulletproof provider reliance** — Heavy use of ASNs known for lenient abuse handling points to **long-term operations** over smash-and-grab.
- **Namespace strategy** — Consistent "shadowbroker" root across `.net`, `.io`, and "-backup.com" domains suggests **clear internal processes** for naming, staging, and backup operations.

Task 1.3: MITRE ATT&CK Mapping

Instructions: Review `shadowbroker_ttps.csv` and analyze the tactics and techniques.

Campaign_ID	Date	Tactic	Technique	Technique_ID	Frequency	Description
SB_2023_001	2023-01-15	Initial Access	Spearphishing Link	T1566.002	High	Phishing emails with malicious links to payload ser
SB_2023_001	2023-01-15	Execution	PowerShell	T1059.001	High	PowerShell scripts for payload execution and C2 com
SB_2023_001	2023-01-15	Persistence	Registry Run Keys	T1547.001	Medium	Registry modifications for persistence across reboo
SB_2023_001	2023-01-15	Defense Evasion	Obfuscated Files or Information	T1027	High	Payload obfuscation using custom encryption
SB_2023_002	2023-02-01	Defense Evasion	Process Injection	T1055	High	Code injection into legitimate Windows processes
SB_2023_002	2023-02-01	Credential Access	Credential Dumping	T1003	Medium	Extraction of credentials from LSASS memory
SB_2023_002	2023-02-01	Credential Access	Input Capture	T1056.004	Medium	Keylogging for credential capture
SB_2023_003	2023-03-10	Discovery	Network Service Scanning	T1046	High	Internal network reconnaissance using port scanning
SB_2023_003	2023-03-10	Discovery	System Information Discovery	T1082	High	Gathering system information for targeting
SB_2023_003	2023-03-10	Lateral Movement	Pass the Hash	T1550.002	High	Using stolen credentials for lateral movement
SB_2023_003	2023-03-10	Lateral Movement	Remote Services	T1021.002	Medium	RDP exploitation for lateral movement
SB_2023_004	2023-04-05	Exfiltration	Exfiltration Over C2	T1041	High	Data exfiltration through C2 channel
SB_2023_004	2023-04-05	Exfiltration	Data Compressed	T1002	Medium	Compression of data before exfiltration
SB_2023_004	2023-04-05	Command and Control	Application Layer Protocol	T1071.001	High	C2 communication over HTTP/HTTPS
SB_2023_005	2023-05-12	Persistence	Scheduled Task	T1053.005	Medium	Scheduled tasks for persistence and execution
SB_2023_005	2023-05-12	Execution	Scheduled Task	T1053.005	Medium	Scheduled tasks for periodic malware execution
SB_2023_006	2023-06-08	Initial Access	Supply Chain Compromise	T1195.002	Low	Compromised software updates as attack vector
SB_2023_006	2023-06-08	Persistence	DLL Search Order Hijacking	T1574.001	Medium	DLL hijacking for persistence

(END)

. 1: Which tactics are most frequently observed?

Tactic	Frequency	Percentage
Initial Access	High	~15%
Execution	High	~15%
Defense Evasion	High	~15%
Discovery	High	~15%
Lateral Movement	High	~15%
Exfiltration	High	~15%
Persistence	Medium	~5%
Credential Access	Medium	~5%

. 2: What is the most common attack chain (sequence of tactics)?

- **Initial Access — Spear-phishing link (T1566.002)**
- **Execution — PowerShell payload execution (T1059.001)**
- **Persistence — Registry Run Keys (T1547.001)**
- **Defense Evasion — Process Injection (T1055)**
- **Credential Access — Credential Dumping (T1003)**
- **Discovery — Network service scanning (T1046)**
- **Lateral Movement — Pass-the-Hash (T1550.002)**
- **Exfiltration — Exfiltration over C2 channel (T1041)**

. 3: How does the TTP profile compare to known threat actors?

1. **APT28 (Russia/GRU)**

    - Known for spear-phishing, PowerShell-heavy tooling, process injection, and credential theft.

2. **APT41 (China)**

- Similar multi-stage structure and frequent C2 exfiltration.

3. Lazarus Group (North Korea)

- Overlaps in credential dumping and lateral movement, though infrastructure placement differs.

SECTION 2: OPERATIONAL INTELLIGENCE ANALYSIS (25 points)

Task 2.1: Victimology Analysis

Instructions: Review `shadowbroker_campaigns.csv` and analyze target characteristics.

```
┌──(kali㉿kali)-[~/Downloads]
└─$ column -t -s',' shadowbroker_campaigns.csv
Campaign_ID  Campaign_Name             Start_Date  End_Date    Target_Industry          Target_Region  Target_Count  Attack_Type              Success_Rate
Initial_Access_Vector                Dwell_Time_Days  Data_Exfiltrated_GB  Objectives                                Sophistication_Level  Notes
SB_2023_001  Operation Secure Update   2023-01-15  2023-02-01  Financial Services       North America  47            Spear-Phishing           45%
Email with malicious attachment    14                2.3                  Credential theft and reconnaissance       High                  Initial campaign ta
rgeting US and Canadian banks
SB_2023_002  Operation Session Verify  2023-02-01  2023-03-10  Cryptocurrency Exchange  Europe         23            Spear-Phishing           52%
Email with malicious link          21                5.7                  Account takeover and fund theft           Very High             Expanded targeting
to European crypto exchanges
SB_2023_003  Operation System Check    2023-03-10  2023-04-20  Payment Processors       Asia-Pacific   34            Spear-Phishing           48%
Email with trojanized document     18                3.2                  Payment system compromise                 Very High             Geographic expansio
n to Asia-Pacific region
SB_2023_004  Operation Update Check    2023-04-05  2023-05-15  Financial Services       North America  56            Spear-Phishing           55%
Email with macro-enabled document  25                8.1                  Lateral movement and data exfiltration    Very High             Repeated targeting
of North American institutions
SB_2023_005  Operation Version Check   2023-05-12  2023-06-05  Banking Infrastructure   Europe         19            Spear-Phishing           58%
Email with ISO attachment          19                4.5                  SWIFT system reconnaissance               Very High             Targeting of core b
anking infrastructure
SB_2023_006  Operation Supply Chain    2023-06-08  2023-06-15  Software Vendor          Multiple       3             Supply Chain Compromise  15%
Trojanized software update         7                 0.8                  Lateral movement to downstream customers  Very High             Low success rate bu
t high impact potential
```

. 1: What industries are targeted? (Rank by frequency)

Industry	Campaign Count	Percentage
Financial Services	2	33%
Cryptocurrency Exchange	1	17%
Payment Processors	1	17%
Banking Infrastructure	1	17%
Software Vendor (Supply Chain)	1	17%

. 2: What geographic regions are targeted? (Rank by frequency)

Region	Campaign Count	Percentage
North America	2	33%
Europe	2	33%
Asia-Pacific	1	17%
Multiple Regions	1	17%

. 3: What does the targeting pattern suggest about threat actor interests?

The targeting pattern strongly suggests that ShadowBroker is focused on:

- **High-value financial assets**
- **Institutions with large transaction volumes**
- **Organizations connected to global payment ecosystems**

. 4: Is there evidence of strategic focus or random targeting?

Task 2.2: Campaign Timing Analysis

Instructions: Analyze the campaign timeline and temporal patterns.

. 1: What is the timeline of observed campaigns?

Campaign	Start Date	End Date	Duration (Days)
SB_2023_001	2023-01-15	2023-02-01	**17**
SB_2023_002	2023-02-01	2023-03-10	**37**
SB_2023_003	2023-03-10	2023-04-20	**41**
SB_2023_004	2023-04-05	2023-05-15	**40**

SB_2023_005	2023-05-12	2023-06-05	**24**
SB_2023_006	2023-06-08	2023-06-15	**7**

. 2: Are there gaps or patterns in campaign timing?

Yes — several clear patterns show up:

1. Continuous month-to-month operations

Each campaign begins almost immediately after the previous one ends.
This indicates **ongoing, planned activity** rather than one-off attacks.

2. Increasing complexity over time

- Early 2023 → spear-phishing only
- Mid 2023 → lateral movement and SWIFT targeting
- Late cycle → supply chain compromise

3. Seasonal / monthly cadence

Every campaign starts **at the beginning or middle of the month**, suggesting internal scheduling or tasking cycles.

4. No random timing

Attack timing is steady and operational, not opportunistic.

. 3: Based on operational timing, what time zone does the threat actor likely operate in?

UTC+1 to UTC+3 (Eastern Europe)

. 4: What evidence supports this time zone assessment?

1. Infrastructure Geography

- Netherlands, Romania, and Russia host the majority of C2 servers.
  These regions fall into UTC+1 to UTC+3.

2. Operational Rhythm

- Campaign launches occur **during business hours** consistent with Eastern Europe.
- Dwell times and activity clusters appear aligned with a structured working day.

3. Consistent Monthly Planning

- Regular monthly operations suggest an actor working normal working cycles, similar to state-aligned APT groups in Eastern Europe.

4. APT-style TTPs

- The TTP profile resembles Russian-aligned groups (APT28 / APT29), who typically operate within these time zones.

Task 2.3: Tool and Technique Assessment

Instructions: Assess the sophistication and resource requirements of observed tools.

. 1: Are tools custom-developed or publicly available?

ShadowBroker relies mainly on custom-developed tools. Their droppers, loaders, and backdoors show unique code structures and even include internal development paths, confirming that they are not simply using publicly available malware. Some components mimic public tools (such as Mimikatz-style credential dumping), but they appear modified and integrated into a larger custom framework.

. 2: What level of operational security (OpSec) is demonstrated?

- All domains use **WHOIS privacy**.
- They use **bulletproof hosting providers** in the Netherlands, Romania, and Russia.

- They deploy **wildcard SSL certificates** (`*.shadowbroker.net`) for encrypted C2 traffic.
- They maintain **multiple C2 tiers** (primary, secondary, tertiary).
- They use **proxy servers** to hide traffic origin.
- They rotate infrastructure and domains across campaigns.

The threat actor demonstrates high operational security. They hide domain ownership, rely on bulletproof hosting, rotate domains, use wildcard SSL certificates, and operate through proxy servers. Their C2 architecture includes redundancy and failover, showing disciplined OpSec suitable for long-running operations.

. 3: What does tool selection suggest about threat actor resources?

- Custom malware families maintained across multiple campaigns.
- Ability to compromise supply chains (SB_2023_006).
- Infrastructure spanning **three countries** and multiple ASNs.
- Redundant C2, proxy layers, and automated domain management.
- "Very High" sophistication ratings in multiple campaigns.

The toolset indicates access to significant resources. Custom malware development, multi-stage payloads, and a resilient C2 network reflect a dedicated development team and stable funding. Their ability to run complex operations, including supply-chain compromise, suggests a well-organized threat actor with resources comparable to major cyber-crime groups or state-aligned operators.

. 4: What does tool sophistication suggest about threat actor capability level?

- Process injection, credential dumping, Pass-the-Hash.
- Multi-stage PowerShell loaders.
- Custom encryption and C2 protocols.
- Consistent "Very High" sophistication ratings.
- Long dwell times (up to 41 days).
- Ability to pivot across regions and industries.

The sophistication of ShadowBroker's tools places them firmly in the high-capability tier. Their malware is modular and stealthy, their lateral movement techniques are advanced, and their overall tradecraft resembles that of state-sponsored APT groups. This suggests an experienced team capable of long-term, multi-region campaigns.

SECTION 3: THREAT ACTOR PROFILING (20 points)

Task 3.1: Motivation Assessment

Instructions: Based on your analysis, assess the motivation of the threat actor.

. 1: Evaluate state-sponsored indicators:

Indicator	Present?	Evidence
Advanced technical capabilities	**Yes** / No	Custom malware families, multi-stage loaders, process injection, Pass-the-Hash, supply-chain compromise.
Strategic targeting patterns	**Yes** / No	Consistent targeting of financial systems across regions (NA → EU → APAC) and SWIFT reconnaissance.
Geopolitical alignment	**Yes** / No	Infrastructure and operational timing point to Eastern Europe/Russia; TTPs resemble Russian-aligned APT groups.
Long-term persistence	**Yes** / No	Dwell times up to 25+ days, repeated campaigns over 6 months, redundant C2 infrastructure

. 2: Evaluate financial motivation indicators:

Indicator	Present?	Evidence
Rapid monetization attempts	**Yes** / No	Campaign notes mention account takeover, fund theft, credential theft, and banking system compromise.
Targeting of high-value assets	**Yes** / No	Banks, payment processors, cryptocurrency exchanges, SWIFT-connected systems.
Ransom demands	Yes / **No**	No ransom behavior is documented in any campaign.
Data theft for sale	**Yes** / No	Large-scale exfiltration of financial data is observed; fits financial-theft or resale motives.

. 3: Evaluate ideological motivation indicators:

Indicator	Present?	Evidence
Public attribution claims	Yes / **No**	No public statements, leaks, or political messaging.
Activist messaging	Yes / **No**	No hacktivist-style communication or defacement.
Political targeting	Yes / **No**	All targets are financial or supply-chain — not political groups or governments.
Defacement activities	Yes / **No**	No website defacement or ideological signaling in any campaign.

. 4: What is your assessment of primary motivation?

ShadowBroker's primary motivation appears to be financial, supported by targeting of banks, payment processors, cryptocurrency exchanges, and SWIFT-related systems. The focus on credential theft, fund theft, account takeover, and high-value financial infrastructure reinforces this assessment. However, the sophistication level, redundancy of infrastructure, and consistent Eastern-European alignment also suggest possible state-sponsored support or tolerance, meaning the group may operate as a financially motivated APT with state alignment or protection.

Task 3.2: Capability Assessment

. 1: Rate technical sophistication (1-10):

Rating: 8 / 10

Justification: ShadowBroker uses a highly advanced technical toolset. Their malware includes custom droppers, loaders, and backdoors with multi-stage execution, credential dumping, process injection, and lateral movement (Pass-the-Hash). They also deploy custom C2 protocols, wildcard SSL certificates, and encrypted outbound traffic. The presence of PDB paths and consistent code structure shows internal development. This level of custom engineering indicates near-APT-level technical capability.

. 2: Rate operational sophistication (1-10):

Rating: _ / 10

Justification: The actor maintains strong OPSEC: privacy-protected domains, bulletproof hosting across three countries, redundant C2 layers (primary/secondary/tertiary), proxy servers, and automated failover mechanisms. Campaigns are consistently timed, with month-to-month operations and long dwell times. The supply chain compromise (SB_2023_006) further shows high operational maturity. Their behaviour matches structured, disciplined teams rather than opportunistic criminals.

. 3: Estimate the resource level required:

Maintaining multiple bulletproof hosting providers, custom malware development, global targeting across multiple regions, and executing a supply-chain attack all require significant financial and human resources. This suggests a professional group with stable funding—potentially state-sponsored or a top-tier financially motivated cybercrime group.

Task 3.3: Geographic Origin Assessment

. 1: What linguistic clues are present in the IOCs or malware?

There are no clear linguistic artifacts (e.g., code comments, strings, error messages) pointing to a specific language or country. The actor uses neutral English strings and removes identifiable metadata, which is consistent with highly disciplined, OPSEC-aware threat groups.

. 2: Based on operational timing, what geographic region is suggested?

UTC+1 to UTC+3 (Eastern European region).

. 3: What infrastructure hosting preferences suggest?

Infrastructure is heavily concentrated in:

- **Netherlands (50%)**
- **Romania (30%)**
- **Russia (20%)**

All hosting providers used are bulletproof hosting services, which are commonly leveraged by Eastern European threat actors. This geographic clustering strongly suggests an origin within, or close connections to, Eastern Europe.

. 4: What is your assessment of likely geographic origin?

Most likely Eastern Europe — specifically Russian-aligned or Russia-adjacent regions.

SECTION 4: ATTRIBUTION ASSESSMENT (20 points)

Task 4.1: Attribution Hypothesis

Instructions: Based on your complete analysis, develop an attribution hypothesis.

. 1: Which known threat actor group does ShadowBroker most closely resemble?

Select one:

- APT28 (Russia/GRU)
- Lazarus Group (North Korea)
- APT41 (China)
- FIN7 (Unknown)
- Unknown Group

Justification:

APT28 (Russia/GRU)

ShadowBroker most closely resembles **APT28**, a Russian-aligned advanced persistent threat group, based on multiple converging indicators from technical, operational, and strategic analysis.

1. Infrastructure Clustering in Eastern Europe
ShadowBroker uses bulletproof hosting providers in the Netherlands, Romania, and Russia — a pattern strongly associated with Eastern European and Russian APT operations. Their C2 infrastructure is structured, redundant, and aligned with GRU-style tradecraft.

2. Operational Timing (UTC+1 to UTC+3)
Every campaign aligns with working hours in Eastern Europe. This pattern of structured timing is a hallmark of state-backed Russian teams rather than loosely organized criminal groups.

3. High Technical Capability Matched to APT28

- Multi-stage custom malware
- Pass-the-Hash lateral movement
- Process injection and credential dumping
- Encrypted C2 channels
  These techniques directly parallel well-documented APT28 behaviours.

4. Strategic Targeting of Financial Systems
APT28 is known to support Russian strategic and financial interests. ShadowBroker's focus on banks, SWIFT, cryptocurrency exchanges, and payment processors fits this geopolitical alignment.

5. Long-term Persistence & Campaign Structure
ShadowBroker conducts month-to-month operations with long dwell times (7–41 days) and uses redundant C2 servers — a pattern very similar to how APT28 runs extended campaigns.

6. OPSEC Maturity Consistent with State-Backed Groups
Wildcard certificates, attacker-controlled DNS, bulletproof hosting, and structured domain rotation indicate a professionalized threat actor with organizational backing.

Task 4.2: Evidence Documentation

. 1: List your top 3 supporting pieces of evidence:

Evidence 1:

Eastern European Infrastructure Clustering

ShadowBroker consistently uses bulletproof hosting providers located in **the Netherlands, Romania, and Russia**.
These regions are commonly linked to Eastern-European and Russian-aligned cyber operations.
The distribution — NL (50%), RO (30%), RU (20%) — strongly suggests an Eastern European operational base

Evidence 2:

TTP Alignment with Russian APT Groups (APT28-style)

ShadowBroker uses **custom malware**, **Pass-the-Hash**, **process injection**, **PowerShell loaders**, and **multi-stage C2 communication**.
These techniques closely match well-documented behaviours of **APT28 (Russia/GRU)** and other Russian-aligned APTs.
The sophistication level indicates a highly trained, well-funded team consistent with state-supported operations.

Evidence 3:

Operational Timing (UTC+1 to UTC+3)

Campaign execution and activity windows align tightly with **Eastern European business hours**.
The month-to-month cadence, long dwell times, and structured working-hour

behaviour reflect disciplined operations typical of professional APT teams in this region.

. 2: List potential alternative hypotheses:

Alternative 1:

Lazarus Group (North Korea)

Although ShadowBroker most closely resembles Russian-aligned APT groups, **Lazarus Group remains a plausible alternative** because they also:

- Target global **financial institutions**
- Conduct **large-scale theft operations** involving banks and crypto exchanges
- Use **custom malware** with multi-stage loaders
- Perform **credential theft and lateral movement**

Why it's weaker:
ShadowBroker's infrastructure sits entirely in Eastern Europe (NL/RO/RU), and the operational timing matches Eastern European business hours — not North Korean. No DPRK-typical code structures or ideological elements appear.

Alternative 2:

APT41 (China)

APT41 is another possible match, as they:

- Conduct **financially motivated campaigns** alongside espionage
- Use custom backdoors and multi-stage tools
- Target supply-chain vendors (similar to SB_2023_006)

Why it's weaker:
APT41 typically uses Asian hosting providers, Chinese-language code artifacts, and politically aligned espionage targets — none of which appear in ShadowBroker's data. The motivation and TTPs only partially overlap, while the geographic and infrastructure signatures do not fit.

Task 4.3: Confidence Assessment

. 1: What is your confidence level in this attribution?

Select one:

- HIGH CONFIDENCE
- MEDIUM CONFIDENCE
- LOW CONFIDENCE

Justification:

MEDIUM CONFIDENCE

There is strong evidence pointing toward a Russian-aligned Eastern European threat actor — including infrastructure clustering (Netherlands, Romania, Russia), UTC+1 to UTC+3 operating times, and TTPs that closely match APT28-style behaviour.
However, there are **no definitive identifiers**, such as code-language markers, operational claims, human intelligence sources, or external vendor confirmation. Because attribution is based on behavioural and infrastructure correlations rather than direct proof, **medium confidence** is the most accurate and defensible rating.

. 2: What additional information would increase your confidence?

- **Code-level overlaps** with known APT28 malware families (e.g., identical function structures, encryption routines, compiler metadata).
- **Language or cultural artifacts** in malware strings, debug paths, or error messages.
- **External intelligence reporting** from vendors (Mandiant, CrowdStrike) correlating ShadowBroker infrastructure with known Russian operations.
- **Infrastructure reuse confirmation**, such as IPs or domains previously attributed to APT28.
- **Human intelligence or diplomatic reporting** linking campaign timing to geopolitical events.
- **Telemetry from victim environments** showing the same toolset used in previously confirmed APT28 intrusions.

. 3: What gaps exist in your analysis?

- **No linguistic evidence** in the malware (no embedded comments, code markers, or native-language strings).
- **No direct infrastructure reuse** that conclusively ties ShadowBroker to a public APT group.
- **Limited visibility** into the threat actor's internal communication, tasking, or origin point.
- **No access to full malware reverse-engineering** results or sandbox forensic data.
- **Campaign objectives are mostly financial**, which overlaps with many APT and cybercrime groups — making attribution more ambiguous.
- **No victim-side logs** (EDR, SIEM, server telemetry), which limits behavioural correlation.

SECTION 5: EXECUTIVE SUMMARY (10 points)

Instructions: Write a 2-3 paragraph executive summary of your threat intelligence assessment.

Threat Actor Profile Summary

ShadowBroker is a highly capable threat actor conducting sustained, financially motivated cyber operations against the global financial sector. Over a six-month period, the group targeted banks, payment processors, cryptocurrency exchanges, and SWIFT-connected infrastructure across North America, Europe, and Asia-Pacific. Their campaigns consistently used spear-phishing as the primary entry vector, supported by custom-built malware families capable of credential theft, network reconnaissance, and multi-stage command-and-control communication.

The technical and operational behaviour of ShadowBroker demonstrates advanced sophistication. Their malware is modular and custom-developed, and their infrastructure spans multiple bulletproof hosting providers in the Netherlands, Romania, and Russia. The group uses wildcard SSL certificates, redundant C2 layers, and proxy nodes to maintain persistence and evade

detection. Their operational tempo, toolset maturity, and structured campaign cadence closely resemble known Russian-aligned APT groups.

Overall, ShadowBroker appears to be a well-resourced and organized actor with clear financial objectives and possible state alignment. Their long dwell times, geographic expansion, and ability to conduct both direct targeting and supply-chain compromise place them at the upper tier of threat actor capability.

Key Findings

- ShadowBroker uses **custom malware families** with multi-stage loaders, credential dumping, and process injection capabilities.
- All campaigns showed **high or very high sophistication**, with structured operational patterns and long-term persistence.
- Infrastructure is clustered in **Eastern Europe (Netherlands, Romania, Russia)** using bulletproof hosting and wildcard certificates.
- Targeting focuses on **financial institutions, payment systems, crypto exchanges, and supply-chain vendors**.
- Operational timing and TTPs strongly resemble **Russian-aligned APT groups**, with medium-confidence attribution to APT28-style activity.
- The group demonstrates **advanced OPSEC**, including DNS rotation, multi-tier C2, and encrypted exfiltration channels.

Recommended Actions

- Block and monitor all **identified ShadowBroker IPs, domains, and SSL fingerprints** at the network perimeter.
- Deploy **EDR solutions** capable of detecting process injection, credential dumping, and suspicious PowerShell activity.
- Strengthen **email security controls** to mitigate spear-phishing, including DMARC enforcement and user phishing awareness training.
- Implement **network segmentation** to limit lateral movement and protect high-value financial systems.
- Enable **multi-factor authentication (MFA)** and enforce strict credential hygiene to reduce the impact of Pass-the-Hash attacks.
- Continuously monitor for **DNS queries to ShadowBroker-controlled infrastructure** and unusual outbound data transfer patterns.